

describes computer systems as having some kind of vulnerability that is then exploited by an attacker. However, the most important vulnerability is human gullibility and lack of understanding. Conversely, the most important form of defence is a reasonable understanding of security issues combined with care and vigilance.

If you received an email from some unknown source, telling you to click on a link to “See Britney Spears naked”, would you click on that link? Most people nowadays know the danger involved and that clicking on such a link is likely to lead to computer infection of some kind. Unfortunately, there are still some who do not.

But what if the email at least appeared to be from a known source, and one that you knew had your email address. What if it appeared to be from your own bank, and included all the right graphics, logos and everything? You may be much more likely to click on the link in order to reset your PIN or password, as suggested. What if the link led you to a web page, apparently with the correct URL, that looked exactly like your bank’s correct page, complete with Verisign security certificate logo (the little lock in the bottom right of the window frame). Would you then enter your existing user name and password, thereby allowing the attacker to empty your bank account, or purchase goods online and send them to Africa?

Such attacks are more rare than offers of naked Britneys, but the attackers are getting this sophisticated, and making increasing efforts to make money from such attacks. They continue to do so only because previous and less sophisticated attacks have proved successful. People have clicked on the links, entered personal information, and lost money as a result.

In the following pages, we will describe the most likely types of security problems that you will encounter and give you some advice on how to behave on the internet — what to do and what not to do. Software can also of course help considerably, as long as you do not allow yourself to become complacent — you may have the best known anti-virus and anti-spyware software installed, but you still need to take care.

Dangers on the internet

The method of attack we described earlier, of an email purporting to come from your bank and asking for personal information, is known as phishing. Basically, phishing is a

form of con-trick, and any such trick stands a better chance of working the more believable it is. The simplistic attacks seem to be falling in number, presumably because people are increasingly aware of the problem, and so attackers are becoming more sophisticated.

Perhaps the most common form of attack used in phishing is known as cross-site scripting (XSS). In this method an attacker will insert code in the embedded link — not the link that you will necessarily see — that will attempt to manipulate a web application, usually so that some code is inserted into the page that will be displayed in your browser. This doesn’t change anything on the server, but your browser will receive an amended form of the page, and will execute the malicious code as if it had come from that server. What you see will be the correct page of, say, your bank, but it will behave and perhaps appear differently — usually it will send you



This partial screenshot is of a genuine email from a UK utility company presenting a link allowing the user to pay a bill. The link is of a known and correct URL, and the actual link that would be followed — which is displayed in the window frame at bottom left — matches correctly the link in the text. Even though this is clearly correct, it is better practice never to use such a link, but use your bookmarked link to your utility company in order to pay such a bill. Even a small difference in the actual link might take you to a spoofed site

to another page that will have been crafted by the attacker.

In an extended form of this attack, known as persistent XSS, the manipulated URL is stored on a server in some form or another — in a database, forum content, and so forth — and is then accessed by unsuspecting users. In this case, you do not have to click on a manipulated URL in a phishing email, but it exists in some other source that you might stumble upon innocently.

Another variant on this kind of attack is known as frame-spoofing, which can also be triggered by a manipulated URL in an email. Frames have long been considered to be insecure by security experts, and their use is slowly fading away, but there are still a great number out there. In frame spoofing — first recognised by Microsoft back in the days of Windows 3.1 — an attacker is able to insert their own window as a frame within the